ADAPTCLOUD

PARTNER BRIEF — CO-DELIVERY CONSTRUCT

Managed NIST SP 800-171 compliance: co-delivery construct and commercial terms

VERSION	DATE OF ISSUE	STATUS	PREPARED FOR
1.0	September 6, 2026	For discussion	Prospective co-delivery partner

DISTRIBUTION

Restricted — named recipients

1 Executive summary

1. **The obligation survived the program suspension, and most of the market has not adjusted.** Phase II of CMMC was suspended on July 13, 2026.[1] DFARS 252.204-7012, Phase I self-assessment, and submission of a NIST SP 800-171 Rev 2 score to the Supplier Performance Risk System all remain in force.[2] What changed is the deadline, not the requirement. Demand has moved from certification readiness to evidence maintenance, and it recurs annually.

2. **Competitors built their offers around a date that no longer exists.** Any proposition whose close depended on November 10, 2026 has lost it. We regard the next four to six quarters as an unusually open window for an offer priced on continuous evidence rather than on a certification sprint.

3. **The binding constraint on this practice area is delivery repeatability, not demand.** Readiness engagements are built by hand, by senior people, every time. Unit cost does not fall across engagements, so the practice scales only by hiring. AdaptCloud supplies the engine that breaks that curve: a versioned control library, a host scanner, remediation playbooks, and governed cloud landing-zone modules.

4. **We publish automated coverage rather than characterize it.** Seventeen practices across six of fourteen domains are automated today (Exhibit 3). We state that number in the first meeting. In this category, an overstated scope is discovered during the client's assessment, which costs the account and the reference at the same time.

5. **We propose a bounded 60-day pilot on one mutual client,** judged on a single quantitative criterion defined at section 9. If that number does not move, the construct does not scale for the Partner and we would both rather know inside a quarter.

2 Market context

The Department suspended Phase II of the CMMC program on July 13, 2026, deferring the third-party assessment requirement that had been set for November 10, 2026, and stood up a reform task force.[1] Phase I self-assessment, the DFARS safeguarding clause, and the underlying NIST standard were untouched.[2]

Two things follow for the supplier base, and in our experience only the first is well understood. Compliance still attaches to award, and a supplier's SPRS score decays as its estate drifts from the configuration it was scored against. That makes the requirement recurring rather than one-time. Less well understood is the second: with the deadline gone, the urgency that carried most vendors' sales motions went with it. Offers positioned on fear of a date are stalling. Offers positioned on the cost of staying current are not.

The pattern we see in Level 2 programs is that the assessment is rarely the hard part. The twelve to eighteen months of evidence discipline in front of it is where supplier programs fail, and it is the part no one has productized. That is the gap this construct is built for.

Published cost estimates appear at Exhibit 1. They are secondary sources, unvalidated by us, and we present them to fix the order of magnitude behind the pricing at section 7 rather than as a business case.

EXHIBIT 1 — INDICATIVE COST OF LEVEL 2 COMPLIANCE, PER CONTRACTOR

MEASURE	INDICATIVE RANGE	BASIS
First compliance cycle, total	$75,000 – $300,000	Industry estimate, inclusive of assessment fees, remediation, and documentation[3]
Third-party assessment component	$30,000 – $150,000	Subset of the above[3]
Three-year lifecycle, small contractor	~$488,000	Departmental estimate as reported[4]
Purpose-built tooling, annual	$600 – $1,800	Prevailing market range for small-supplier tools[5]
Mid-market GRC platform, annual	$10,000 – $80,000	Published entry and scale pricing for a comparator platform[6]

All figures are list or reported estimates in US dollars and exclude taxes. We have not verified the underlying methodologies. Validating them against observed engagement effort is a pilot workstream (section 9).

3 Solution description

The offer has three separable parts: the intellectual property, the integrated solution, and the delivery construct. The Partner keeps the client relationship and supplies the delivery organization. We supply the engine, the enablement, and second-line support. We do not go direct into accounts the Partner brings.

EXHIBIT 2 — CAPABILITY ARCHITECTURE

COMPONENT	FUNCTION	EXECUTION LOCATION	OWNERSHIP
Host audit binary	Assesses a host against the control library, applies remediation on an explicit flag, re-verifies, and emits both human-readable and machine-readable output. Returns a non-zero exit status while findings remain open, so it drops into a pipeline without a wrapper.	Client host	AdaptCloud
Control library	Versioned practice definitions with NIST SP 800-171 Rev 2 references, severity, and remediation actions. Every evidence bundle records the library revision that produced it, which is what makes a finding reproducible six months later.	Engine	AdaptCloud
Cloud landing zone	Infrastructure as code for a governed application platform, policy-as-code enforcement, and a discrete workload identity per AI agent, aligned to published cloud adoption framework guidance.	Client tenant	AdaptCloud
Container baseline	Hardened managed-Kubernetes infrastructure as code with federated single sign-on enforced at the boundary.	Client project	AdaptCloud
Evidence pipeline	Assembles system security plan narrative and plan-of-action entries from assessment output, with a provenance classification on every item (section 4.1).	Partner-operated	Joint

Derived from inspection of the AdaptCloud repositories as of the date of issue. Component names are descriptive rather than commercial product names.

We consider the landing-zone component the least substitutable thing we bring. Governing AI agent identities inside a policy-enforced environment is a control problem the defense supplier base is walking into now, with no established pattern and no tooling aimed at it. Everything else in Exhibit 2 has competitors. That does not.

4 Automated coverage

We publish coverage. We do not characterize it, and we do not let a sales conversation imply more than Exhibit 3 shows. Overstating automated scope is the single fastest way to lose a compliance account, because the correction arrives in front of the client's assessor rather than in front of us.

EXHIBIT 3 — AUTOMATED PRACTICE COVERAGE BY CONTROL DOMAIN

DOMAIN	CONTROL FAMILY	AUTOMATED CHECKS	DELIVERY METHOD
AC	Access Control	5	Automated, re-verified
AU	Audit and Accountability	3	Automated, re-verified
CM	Configuration Management	3	Automated, re-verified
IA	Identification and Authentication	3	Automated, re-verified
SC	System and Communications Protection	2	Automated, re-verified
SI	System and Information Integrity	1	Automated, re-verified
AT, CA, IR, MA, MP, PE, PS, RA	Eight remaining domains	—	Practitioner-delivered
Total automated practices		**17**	**of 110 Level 2 practices**

Derived by enumerating the control identifiers implemented in the AdaptCloud scanner as of the date of issue, and verifiable against the source repository. The eight remaining domains are largely policy, training, and process controls, a substantial share of which no vendor can verify automatically. Coverage is the product roadmap and will increase; we make no commitment on timing in this document.

Read that table the way an assessor will. The automated set is the configuration evidence that is expensive to gather by hand and worthless if it is stale, which is exactly the part worth mechanizing. The human-delivered set is policy and process work that consultants should be doing anyway, and it moves faster once the technical half is already evidenced. That division is the offer, and it is more defensible than a claim of full coverage.

4.1 Provenance classification

The evidence pipeline uses generative AI for narrative drafting. In a finished package a generated sentence and an observed system fact look identical, and conflating them is the fastest route to an indefensible submission. We separate them in the data model so they cannot be merged in output.

Observed — **Machine-observed.** The scanner read live configuration. Carries host, timestamp, and the identifier of the check that produced it.

Asserted — **Model-asserted.** Drafted from context by the AI layer. Reviewable, and never presented as an observation.

Attested — **Human-attested.** Signed by a named individual. Required before any model-asserted item enters a submitted package.

We regard this as the precondition for using AI in compliance work at all. A partner who cannot show an assessor which sentences were observed and which were drafted has an efficiency story and no defense.

5 Data boundary and regulatory scope

The scanner runs on the client host and returns control status, findings, and scores. Configuration artifacts, system files, and controlled unclassified information stay inside the client environment. This is an architectural constraint we adopted before the first contract, not a limitation waiting to be fixed.

The reason is specific. A cloud service that stores or processes CUI falls under DFARS 252.204-7012 and needs FedRAMP Moderate authorization or documented equivalency, which is a six-figure, multi-quarter undertaking that would land on both parties. Designing the boundary in is cheap. Remediating it after the first client uploads a system security plan is not. Where a client wants a fully hosted posture, that is a separate offering with its own authorization path and its own commercial treatment, and it is out of scope here.

6 Strategic position and long-term gain

The immediate case is margin on 800-171 work. The durable case needs stating carefully, because the obvious version of it is wrong and we would rather say so here than have the Partner discover it in eighteen months.

6.1 Two regimes are landing on one estate

Defense suppliers are deploying AI agents into the same environments that hold controlled unclassified information. That puts two obligations on one estate. NIST SP 800-171 and DFARS 252.204-7012 govern the data. A newer class of requirement governs the agent itself: what it may do, under whose identity, and whether its actions can be attributed after the fact.

AIUC-1 is the clearest expression of the second class. Published by the Artificial Intelligence Underwriting Company, it sets 51 requirements and roughly 130 controls across six pillars covering security, safety, reliability, accountability, data and privacy, and society. Certification is audited by an accredited third party, valid for twelve months, and sustained by quarterly technical testing. Its distinguishing feature is that conformance is backed by insurance, so an agent's compliance carries a priced financial guarantee rather than only a certificate.[7] The first enterprise automation platform certified to it did so in March 2026.[8]

6.2 Generic agent governance will be commoditized, and we do not build a case on it

An assurance regime with insurer backing, accredited auditors, and platform vendors already certifying will not leave a gap under it for long. We expect the major automation and cloud platforms to ship baseline agent identity, policy binding, and action logging as native features on a twelve to twenty-four month horizon, because certification pressure gives them a direct commercial reason to.

Any proposition whose long-term case rests on being the party that governs AI agents is therefore building on ground that is scheduled to disappear. We are not making that argument, and a partner should discount anyone who does.

6.3 The position that holds is agent governance inside the CUI boundary

What the platforms will not follow us into is the regulated boundary. Serving CUI workloads means accepting DFARS flow-down, and a hosted service that touches CUI needs FedRAMP Moderate authorization or documented equivalency. That is an unattractive proposition at platform scale and a deliberate one at ours. The result is a narrow, durable position with three components that do not commoditize on the same schedule:

1. **The boundary itself.** Findings and scores cross it, artifacts and CUI do not (section 5). A generic platform feature is not architected around that constraint, and retrofitting it is a re-platforming exercise rather than a release.

2. **A control library written against a specific regulated catalog.** Native platform governance answers to an assurance standard. It does not produce a NIST SP 800-171 Rev 2 finding with a practice identifier, a severity, and a remediation an assessor will accept.

3. **Provenance tied to a submission that carries legal weight.** Distinguishing machine-observed from model-asserted matters everywhere. It matters differently when the output is a system security plan supporting a score submitted to a federal system of record.

Stated as one sentence: we are not the firm that governs AI agents. We are the firm that governs AI agents where the data is regulated and the evidence has to survive an assessor. That claim is smaller, and it will still be true when the first one is not.

EXHIBIT 4 — WHERE OUR SUBSTRATE CONTRIBUTES TO AGENT-ASSURANCE CONTROL THEMES

CONTROL THEME	WHAT THE ASSURANCE REGIME ASKS	ADAPTCLOUD CONTRIBUTION
Accountability	Agent actions are attributable to a bounded identity, after the fact.	A discrete workload identity per agent rather than agents sharing a service principal. Expected to become a platform feature; valuable to us because it is delivered inside the regulated boundary.
Security	Agent authority is constrained by enforced policy, not by configuration convention.	Policy-as-code enforcement at management-group scope, so a non-conforming workload cannot deploy rather than being detected afterward.
Reliability	Claims about agent behavior are evidenced and repeatable.	Versioned control library. Every evidence bundle records the library revision that produced it, so a finding is reproducible months later against a named catalog.
Data and privacy	Regulated data does not leave its authorized boundary through the agent.	The architectural constraint at section 5. This is the column where a general-purpose platform is least likely to compete.
Accountability, AI-generated content	Machine output is distinguishable from human assertion in the record.	Provenance classification at section 4.1, enforced in the data model, and carried through to a federal submission rather than an internal log.

Our own analytical reading of published descriptions of agent-assurance control themes, prepared to show where our capability lands and where we expect to be displaced. It is not an accredited crosswalk, we hold no AIUC-1 certification, and nothing here should be represented to a client as conformance with that or any other standard. A formal mapping requires the published control text and an accredited assessor.

6.4 What the Partner gains across three horizons

0–12 mo — **Margin and repeatability on work already being sold.** Readiness engagements stop being hand-built. The library ratio at section 9 measures it directly, and it is the difference between a practice that scales by hiring and one that does not. This horizon does not depend on any view of agent assurance.

12–24 mo — **The regulated-boundary position, entered before the category is contested.** Not agent governance broadly, which the platforms will take. The narrower line is a defense client running agents against CUI who needs one party accountable for both regimes. Entering while the platforms are still building general features is what buys the reference accounts.

24 mo + — **Optionality on other regulated verticals, not a second moat.** The pattern is a governed landing zone, enforced policy, per-agent identity, and provenance-classified evidence against a named control catalog. Healthcare, financial services and critical infrastructure have the same structure and a different catalog, and the engine treats the catalog as the variable. We present this as optionality the Partner may exercise rather than as defensibility, because each vertical has incumbents and none of them is us.

One consequence is worth naming because it is unusual in advisory work. Where agent assurance is insurance-backed, an underwriter eventually prices the risk of a client's agent estate. A partner that can demonstrably reduce that posture inside a regulated boundary has a value story with a number attached, which is rare in this profession and hard for a competitor to argue against.

7 Commercial construct

We price on assessment scope, expressed as hosts and enclaves, and never on user seats. Scope is the unit a compliance buyer already reasons in. Seat pricing penalizes the small subcontractors the primes most need brought to standard, which is the segment where volume lives.

EXHIBIT 5 — INDICATIVE LIST POSITIONS

TIER	SCOPE	LIST, ANNUAL	INCLUDED
Lookup	Unrestricted	Nil	Control reference, 800-171 Rev 2 mapping, score calculator. Demand generation, not gated.
Scan	≤ 10 hosts	$990	Scheduled assessment, machine-readable evidence, SSP and POA&M export, score tracking.
Harden	≤ 25 hosts	$2,990	Remediation with rollback, drift re-verification, fleet view, evidence bundle.
Enclave	≤ 100 hosts	$18,000 – 30,000	Landing zone and container baselines, agent identity governance, federated sign-on.
Readiness	Per engagement	$8,000 – 20,000	Fixed-fee scaffold, delivered by Partner practitioners on the engine.

List positions in US dollars, exclusive of taxes and of the client's own cloud consumption, which the client contracts and pays directly and which we never bundle. Partner economics are set against these positions in the co-delivery agreement and are not stated here. The enclave position varies with the number of landing zones and workload environments in scope and is quoted per client.

Against Exhibit 1, the annual subscription tiers land under one percent of a first compliance cycle. We recommend anchoring the client conversation on the practitioner hours displaced from evidence gathering, never on a competitor's list price. The moment this is compared tool to tool it becomes a feature argument, and feature arguments in this category are won by whoever is most willing to overstate coverage.

One structural point we would press in the agreement: contract this as an annual subscription with delivery included, not as time and materials. The work is identical and the margin is similar, but T&M re-anchors the client on an hourly rate, makes the revenue lumpy, and values the practice at a services multiple rather than a product one.

8 Assumptions, dependencies, and risks

8.1 Assumptions

A1 Client hosts are Linux-based and administrative access is provided for the duration of an assessment window.

A2 The Partner provides first-line support to its clients. AdaptCloud provides second-line support to the Partner.

A3	Cloud consumption arising from the landing-zone components is contracted directly by the client and is excluded from every figure in this document.
A4	Market figures at Exhibit 1 are secondary and unvalidated, as stated.
A5	The regulatory position at section 2 is current as of the date of issue and is subject to the reform task force's output.

8.2 Risk register

REF	RISK	ASSESSMENT	MITIGATION	OWNER
R1	Program reform alters or removes the underlying obligation.	Medium / High	Annual contracting with no multi-year commitment. The offer rests on 800-171 and DFARS obligations, which stand independently of the CMMC assessment mechanism.	Joint
R2	Automated coverage at 17 practices is raised as an objection late in a sales cycle.	High / Medium	Coverage published in enablement materials and disclosed at qualification (Exhibit 3), which converts a late objection into an early credibility point.	AdaptCloud
R3	Scope extension puts client CUI inside the engine, triggering authorization obligations.	Low / High	Architectural boundary at section 5, reinforced by contractual restriction in the co-delivery agreement.	Joint
R4	AdaptCloud delivery capacity constrains Partner-led scale.	Medium / Medium	Enablement transfer during the pilot. The library ratio at section 9 is the leading indicator and will show this before capacity binds.	AdaptCloud

Assessment expressed as likelihood / impact. The register is ours and is deliberately short; we expect it to be restated jointly at pilot initiation.

9 Recommended next step

One mutual client, 60 days, four workstreams, one number that decides it.

W1	**Selection.** One mutual client with a live 800-171 obligation and an estate under 25 hosts. Partner-led. We would rather start on a straightforward estate than a flagship one.
W2	**Baseline.** Partner practitioners operate the engine with us in support, not in front. Output is a scored, provenance-classified evidence bundle.
W3	**Remediation and re-verification** of the automated control set, then Partner delivery of the remaining domains on the compressed timeline the technical evidence buys.
W4	**Validation** of the Exhibit 1 cost assumptions against observed engagement effort.

Exit criterion. The share of delivered content that came from existing library components rather than being built for the engagement, measured at close against a target agreed at initiation. We propose this as the only basis on which the pilot is judged. It is the number that tells the Partner whether the second engagement costs less than the first, and it will tell you that a year before the P&L does.

BASIS OF PREPARATION

Prepared from inspection of the AdaptCloud repositories and from the publicly available secondary sources cited below. No independent market research, client interview program or financial audit was undertaken for this document. The coverage figures at Exhibit 3 are derived by direct enumeration of the implemented control set and are verifiable against the source repository. The cost figures at Exhibit 1 are reported estimates we have not validated. Statements on regulatory position are current as of the date of issue and are not legal advice.

SOURCES

1. Reporting on the suspension of CMMC Phase II announced July 13, 2026, and on the constitution of the reform task force. *A-LIGN; Latham & Watkins; Federal News Network*, accessed September 6, 2026.
2. Continuing effect of Phase I self-assessment, DFARS 252.204-7012, NIST SP 800-171 Rev 2 and SPRS submission. *A-LIGN; SC Media*, accessed September 6, 2026.
3. First-cycle Level 2 compliance cost estimates. *IBSS; Godlan*, accessed September 6, 2026.
4. Reported departmental three-year cost estimate for a small defense contractor. *Godlan*, accessed September 6, 2026.
5. Prevailing pricing for purpose-built small-supplier CMMC tooling. *CMMC Map; Totem Technologies published pricing*, accessed September 6, 2026.
6. Published entry and scale pricing for a mid-market compliance automation platform. *Sprinto; vendor-published pricing*, accessed September 6, 2026.
7. Description of the AIUC-1 standard: publisher, requirement and control counts, six risk pillars, third-party audit, twelve-month validity with quarterly testing, and insurance backing. *Mindgard; Tevora; Workstreet; usefini*, accessed September 6, 2026. AdaptCloud has not reviewed the published control text.
8. First enterprise automation platform certified to AIUC-1, March 2026. *UiPath newsroom*, accessed September 6, 2026.